Audit datové kvality podle IT Assurance Guide: Using COBIT - 2. díl

[1.3.2012] D. Pejčoch

Audit kvality dat a procesů zpracování dat

Audit datové kvality (Data Quality Assessment) představuje zpravidla první fázi implementace opatření pro zvýšení kvality dat / informací. Dosavadní přístupy se vesměs shodují, že kromě zjištění aktuálního stavu vlastností dat by měl obsahovat též analýzu užití (stávajícího i potenciálního) jednotlivých datových atributů a zjišťování příčin nekvalitních dat pomocí Root-Cause analýzy. Podle Lee a kol. jej lze realizovat pomocí následujících technik: (1) kvalitativní šetření o datové kvalitě, (2) aplikace kvantitativních metrik, (3) analýza integrity dat podle TDQM (Total Data Quality Management). V praxi se podle [5] uplatňují tyto přístupy:

- Komparativní přístup, tj. srovnání výsledků subjektivního a objektivního assessmentu, zjištění příčin rozdílného vnímání a vzniku nekvalitních dat, návrh nápravných opatření;
- Subjektivní šetření hodnocení kvality dat, důležitosti vlastností, procesů, programů a nástrojů, jehož výsledky jsou často porovnávány v rámci benchmarkingu na globální úrovni nebo na úrovni hodnocení různými rolemi respondentů;
- Data Integrity Assessment, v rámci něhož je nejprve definováno, co znamená datová kvalita z pohledu dat a jejich kontextu (výstupem jsou integritní pravidla pro data) a následně je provedeno porovnání skutečného stavu s nadefinovanými pravidly, na které navazuje analýza kauzálních příčin narušení pravidel a plán nápravy nebo redefinice pravidel (v případě, že se ukážou jako chybná).

V rámci metodiky TQdM (Total Quality data Management) celosvětově uznávaného guru v oblasti datové a informační kvality Larry Englishe lze identifikovat kroky, které odpovídají auditu datové kvality. Jedná se o první tři fáze uvedené metodiky: (1) assessment definice dat a kvality informační architektury, (2) assessment informační kvality a (3) měření nákladů na nekvalitu. V jeho pojetí tyto fáze zahrnují následující kroky:

- S1.1: Identifikace metrik kvality definice dat; stanovení minima nutných atributů dat v rámci definice (např. název, definice, omezení, související byznys pravidla);
- S1.2: Identifikace podstatných skupin informací k hodnocení, tj. takových, jejichž kvalita vede k vysokým nákladům nebo jiným nepřípustným důsledkům;
- S1.3: Identifikace kategorií zainteresovaných subjektů pro vybrané skupiny informací (producenti dat, znalostní pracovníci, externí zákazníci, ...);
- S1.4: Technický assessment kvality definice pro zajištění shody s datovými standardy a směrnicemi;
- S1.5: Assessment kvality informační architektury, assessment návrhu databází a implementace oproti best practices;
- S1.6: Měření zákaznické spokojenosti s definicí;
- S2.1: Potvrzení nebo definice skupin informací k hodnocení;
- S2.2: Definice charakteristik, které budou měřeny (úplnost, shoda s byznys pravidly, přesnost, aktuálnost, ...);
- S2.3: Definice řetězce zdroje => procesy změn => užití informací (informační hodnota) a související náklady pro skupiny informací;
- S2.4: Identifikace zdrojů a procesů, které budou měřeny;
- S2.5: Identifikace zdrojů dat proti nimž je měřena správnost dat;
- S2.6: Náhodný výběr dat pro assessment;
- S2.7: Měření na vzorku dat (automatizovaný assessment / fyzické porovnávání);
- S2.8: Interpretace zjištění a prezentace / reportování úrovně informační kvality;
- S3.1: Nalezení metrik výkonnosti byznysu;
- S3.2: Analýza nákladů na informace (náklady na redundanci, infrastrukturu, ... viz kapitola 1.2.3);
- S3.3: Odvození skupin nákladů pocházejících z chybějících a nekvalitních dat, kalkulace měřitelných nákladů vznikajících v důsledku selhání procesů;
- S3.4: Identifikace segmentů klientů;
- S3.5: Výpočet hodnoty klienta (CLV);
- S3.6: Kalkulace hodnoty informací (měření nákladů na ztracené a promeškané příležitosti v důsledku nekvalitních informací).

Za součást Data Quality Assessmentu lze ještě považovat krok S4.1 v rámci něhož probíhá identifikace zdrojů dat vyžadujících reengeneering.

V rámci jiné metodiky zvyšování kvality dat, publikované Danette McGilvray v [7] pod názvem The Ten Steps Process, audit datové kvality koresponduje s prvními čtyřmi kroky, svým obsahem nepatrně odlišnými od předchozího citovaného přístupu. Jsou jimi: (1) Definice byznys potřeb a přístupu, (2) analýza informačního prostředí, (3) vlastní data quality assessment zahrnující oskórování jednotlivých vlastností dat a konečně (4) hodnocení byznys dopadu těchto naměřených úrovní vlastností dat. Jedná se o tyto konkrétní činnosti:

- S1.1: Prioritizace byznys „záležitostí“ se zaměřením na kritické oblasti nebo problémy, identifikace jejich příčin a prioritizace těchto „záležitostí“;
- S1.2: Plán projektu;
- S2.1: Porozumění relevantním požadavkům (např. regulačním normám);
- S2.2: Porozumění relevantním datům a specifikacím (datový model, dokumentace, ...);
- S2.3: Porozumění relevantním technologiím se současnou identifikací možných dopadů do kvality dat;
- S2.4: Porozumění relevantním procesům;
- S2.5: Porozumění relevantním rolím v rámci organizační struktury;
- S2.6: Definice životního cyklu informace;
- S2.7: Návrh způsobu pořízení dat a sestavení plánu assessmentu;
- S3.1: Hodnocení specifikace dat;
- S3.2: Hodnocení datové integrity;

- S3.3: Hodnocení míry unikátnosti (identifikace duplicit);
- S3.4: Hodnocení míry správnosti;
- S3.5: Hodnocení míry konzistentnosti a synchronizace;
- S3.6: Hodnocení míry aktuálnosti a dostupnosti;
- S3.7: Hodnocení míry snadnosti používání a udržovatelnosti;
- S3.8: Hodnocení míry pokrytí;
- S3.9: Hodnocení prezentační kvality;
- S3.10: Hodnocení vnímání dat jejich uživateli, relevantnosti a důvěryhodnosti;
- S3.11: Hodnocení míry „rozkladu“ dat;
- S3.12: Hodnocení míry „transaktability“, tj. míry, v níž data produkují zamýšlené byznys transakce nebo výsledky;
- S4.1: Sběr katastrofických příběhů jako nejsnazší forma hodnocení byznys dopadu;
- S4.2: Analýza aktuálního a budoucí užití informací;
- S4.3: 5 otázek „proč“ ohledně byznys dopadu kladených uživatelům dat;
- S4.4: Sestavení matice přínosů změn a souvisejících nákladů s identifikací quick wins;
- S4.5: Ohodnocení dopadů a z něj vyplývající prioritizace;
- S4.6: Zmapování dopadu nekvalitních dat do byznys procesů;
- S4.7: Stanovení nákladů nekvalitních dat (identifikace klíčových indikátorů nekvalitních dat => definice / verifikace životního cyklu informace => určení typů nákladů => kalkulace nákladů => kalkulace vlivu do celkových výnosů);
- S4.8: Cost-benefit analýza a z ní vyplývající kalkulace ROI (Return of Investment) uvažovaných změn;
- S5.1: 5 otázek „proč“ kladených uživatelům za účelem identifikace prapůvodních příčin nekvalitních dat;
- S5.2: Vysledování lokalizace problému skrze životní cyklus informace;
- S5.3: Grafické znázornění všech možných příčin pomocí Cause-and-effect / Fishbone diagramu.

IT Assurance Guide: Using COBIT

Standard COBIT (Common OBjectives for IT) pochází původně z dílny ISACA (Information Systems Audit and Control Association). Světlo světa spatřil v roce 1996. Dnešní verze 4.1 pochází z roku 2007 a aktuálně prochází procesem revize, jehož výsledkem bude verze 5. Jak uvádí [14], publikace připravovaných materiálů by měla proběhnout na začátku tohoto roku. Podle [11] COBIT: „představuje sadu všeobecně přijímaných procesů, návodů pro hodnocení, ukazatelů a nejlepších praktických zkušeností, která má za cíl pomoci organizaci maximalizovat užitek, plynoucí z informačních technologií“. Z uvedeného je zřejmé, že standard lze použít jako podporu pro implementaci IT Governance.

[26] a [1] definují IT Governance jako: „specifikaci rozhodovacích práv a soustavy odpovědností za účelem podpory požadovaného chování při využívání IT“. Poněkud srozumitelnější definici nabízí ITGI (viz [10]). Za IT Governance považuje „odpovědnost vedoucích pracovníků a boardu za vedení, vytvoření organizační struktury a procesů zajišťujících, že firemní IT podporuje strategii a cíle organizace“. Důraz je kladen na pochopení IT jako strategického aktiva, prolinkování IT na business strategii (viz např. [10]) a řízení jeho výkonnosti a to zejména z důvodu vysokého podílu nákladů IT na celkových nákladech firmy a vysoké rizikovosti investic do IT (viz [9]).

Vazbu řízení datové kvality na IT Governance lze demonstrovat např. na konceptu Hierarchie řízení dat publikovaném v [1]. Hierarchie uvažuje celkem 5 úrovní řízení, od taktické detekce chyb na úrovni jednotlivých LOB v rámci organizační struktury, přes globální sjednocení standardů napříč firmou, unifikaci kmenových dat (Master Data Management), Data Governance co by strategické řízení dat jako jednoho z klíčových aktiv, až na úroveň IT Governance, kdy jsou všechna IT aktiva řízena za účelem maximalizace jejich byznys přínosů. Pokud firma přijala koncept IT Governance, implementovala jej podle standardu COBIT a řídí data jako jedno z klíčových aktiv, je dle mého názoru též vhodné provádět audit datové kvality podle návodu, který je součástí tohoto standardu. Takový návod představuje IT Assurance Guide: Using COBIT.

IT Assurance Guide: Using COBIT je jedním z devíti základních dokumentů tvořících COBIT 4.1. Představuje společně s IT Governance Implementation Guide: Using COBIT and Val IT dokumenty určené auditorům, resp. assurance profesionálům. Cílem tohoto dokumentu je poskytnout návody pro jednotlivé etapy a činnosti životního cyklu auditu a ujištění. [13] v tomto směru popisuje obsah dokumentu jako „kroky, které musí auditor realizovat“ a „druhy testů ve vazbě na procesy COBIT 4.1“.

Budoucnost IT Assurance Guide v souvislosti s COBIT 5 není v tuto chvíli zřejmá. Předjímané změny v rámci nové verze COBITu si zřejmě vyžádají rovněž aktualizaci tohoto dokumentu, nicméně např. COBIT® 5 Design (viz [15]) se o IT Assurance Guide vůbec nezmiňuje.

Pro účely porozumění dalšímu textu je vhodné vymezit pojmy audit a ujištění (assurance). Pod pojmem audit [11] rozumí: „objektivní ověření stavu, jevu, záměru, skutečnosti se stavem nebo jevem žádoucím, tj. modelem, normou, standardem apod.“ Pojem ujištění lze potom chápat jako „audit delegovaný na jiné subjekty vzhledem k cílům řízení“, tedy „vytvoření závěru o zkoumaném předmětu, za který je odpovědný někdo jiný“. Podle [13] musí každý projekt ujištění splňovat pět vlastností:

- musí jít o vztah mezi třemi partnery: poskytovatelem ujištění, odpovědnou stranou za hodnocený projekt a příjemcem výstupu;
- musí být definován předmět ujištění;
- musí být definována vhodná kritéria ujištění;
- musí být definován proces ujištění;
- musí být zformulován závěr ujištění.

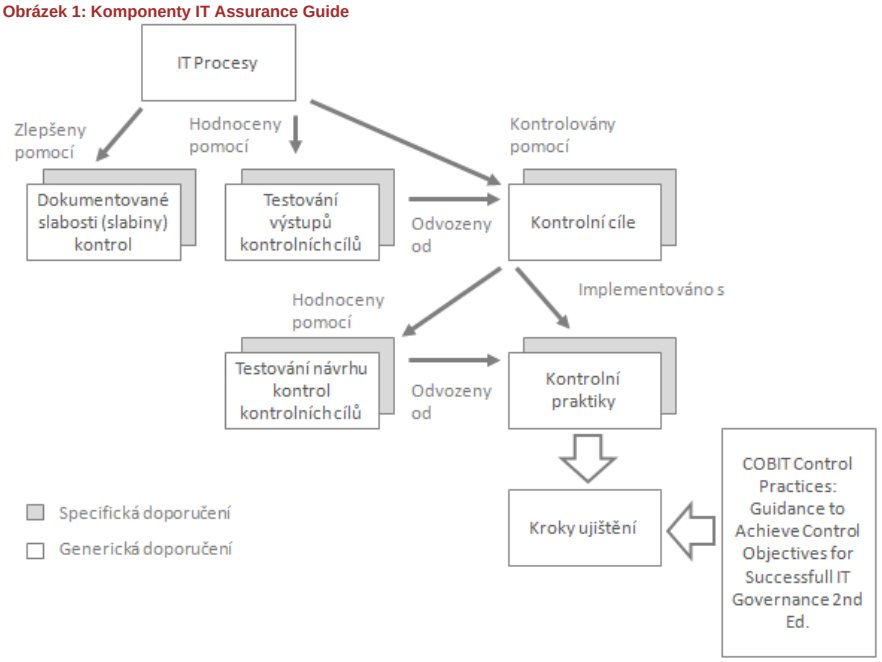
IT Assurance Guide poskytuje doporučení na několika úrovních: (1) procesně specifická doporučení jakým způsobem ověřit zda bylo dosaženo kontrolních cílů a jakým způsobem dokumentovat zjištěné slabiny a (2) na úrovni kontrolních cílů doporučení plynoucí z testování návrhu kontrol pro každý specifický kontrolní cíl. Poskytuje rovněž generická doporučení aplikovatelná na všechny procesy a kontrolní cíle.

Hlavními komponentami IT Assurance Guide jsou podle [13]:

- Kontrolní cíle pro jednotlivé procesy definované v rámci COBIT Framework, představující zamýšlené výsledky a účel dosažený implementací kontrol;

- Drivery hodnot a rizik co by příklady benefitů a rizik, které mohou plynout z dobrých / špatných kontrol;
- Kroky testování v rámci procesu ujištění na úrovni jednotlivých kontrolních cílů, odvozené z kontrolních praktik.

Obrázek 1: Komponenty IT Assurance Guide



Zdroj: upravené schéma z [13]

Vztah mezi hlavními komponentami znázorňuje obrázek č. 1, který vychází z přehledu „poskytovaných doporučení" publikovaném v [13], přičemž navíc reflektuje vazbu konkrétních kroků testování na kontrolní praktiky a skutečnost, že testovací kroky byly odvozeny z COBIT Control Practices: Guidance to Achieve Control Objectives for Successful IT Governance 2nd Edition.

IT Assurance Guide poskytuje pro 34 procesů definovaných v rámci Cobit Framework řadu aktivit ujištění: (1) generické kontroly aplikované na všechny procesy, (2) aplikační kontroly a (3) specifické procesní kontroly. Rámec COBIT poskytuje celkem šest generických procesních kontrol. V přehledu přiloženém k tomuto dokumentu jako Příloha č. 3 představují generické kontroly sekci „Process Control" (řádky 3 až 8). Generické aplikační kontroly představují řádky 223 až 228 (sekce „Application Control"). Zbývající řádky odpovídají specifickým kontrolám vztaženým k jednotlivým procesům v rámci čtyř domén COBIT Framework (Plan and Organise, Acquire and Implement, Delivery and Support, Monitor and Evaluate). V přehledu uvedeném v Příloze č. 3 se snažím jednotlivé kontroly namapovat na úrovně v rámci hierarchie řízení dat. Jsou tak identifikovány kontroly z mého pohledu relevantní pro audit datové kvality prováděný na dané úrovni řízení.

Audit kvality dat a procesů zpracování dat podle IT Assurance Guide

V rámci této kapitoly bych rád představil základní kroky ujištění podle IT Assurance Guide charakterizované tzv. IT Assurance Road Map a současně se pokusil namapovat na tyto kroky jednotlivé fáze auditu datové kvality tak, jak byly představeny v kapitole 1.3. Úplný přehled mappingu formou tabulky je uveden v Příloze č. 3 této práce.

Plánování

V rámci fáze plánování [13] uvádí jako první krok nastavení základních parametrů univerza, které chápe jako oblast odpovědnosti poskytovatele ujištění. K vymezení univerza lze podle [11] použít buď tzv. vertikální přístup, kdy vycházím od strategických byznys cílů směrem k IT cílům, jim odpovídajícím kritickým IT procesům a kontrolním cílům, anebo tzv. horizontální přístup, kdy oblast odpovědnosti vymezuji podle byznys procesů, organizačních jednotek, prvků infrastruktury či jednotlivých datových objektů. Alternativně lze podle [11] k plánu ujištění dospět na základě analýzy rizika s cílem zaměřit se na objekty generující ta nejvýznamnější. Z přístupu Danette McGilvray lze do této fáze přiřadit kroky S2.2 – S2.6 obsahující porozumění relevantním datům, technologiím, procesům, organizační struktuře a vytvoření definice informačního životního cyklu. Z přístupu Larryho Englishe lze uvažovat kroky S1.3 (Identifikace kategorií zainteresovaných subjektů), S2.2 (Potvrzení nebo definice skupin informací k hodnocení) a S2.4: Identifikace, které zdroje a procesy budou měřeny. Tyto kroky jsou potom znovu upřesňovány v rámci definice scope a na počátku fáze realizace. Analýze rizika nejlépe odpovídají kroky S1.1: Prioritizace byznys „záležitostí" v případě McGilvray a S2.3: Definice řetězce informační hodnoty a nákladů pro skupiny informací u Englishe.

Součástí fáze plánování je též předběžný výběr IT kontrolního rámce použitého v rámci ujištění, přičemž doporučeným rámcem je podle [13] v tomto případě COBIT. Na výběr kontrolního rámce lze namapovat v případě McGilvray krok S1.2: Porozumění požadavkům a v případě Englishe krok S1.1: Identifikace metrik kvality definice dat.

Výsledkem vymezení univerza je množina IT procesů ve scope projektu ujištění. U těchto procesů je nejprve vhodné zhodnotit jejich aktuální zralost, což napomůže k identifikaci možných současných gapů mezi skutečným a zamýšleným stavem a současně tak pomůže identifikovat oblasti na něž je nutné se primárně zaměřit. Výstupem této fáze je plán IT ujištění, vytvářený obvykle na roční bázi.

Ani u Englishe ani u McGilvray se nesetkáme s hodnocením zralosti procesů. Prioritizace a sestavení plánu ujištění je u nich prováděna v krocích S1.1 (Prioritizace byznys „záležitostí"), S2.7 (Design pořízení dat a assessment plán) a S1.2 (Identifikace podstatných skupin informací k hodnocení).

Stanovení rozsahu

Tato fáze určuje, jaké IT zdroje a kontrolní cíle budou pokryty. Zahrnuje v sobě prolinkování použitelných IT zdrojů na použitelné IT kontrolní cíle a hodnocení dopadu nedosažení specifických kontrolních cílů. Stanovení rozsahu probíhá v osmi krocích:

- Identifikace driverů pro iniciativu ujištění, např. formou interview se zainteresovanými stranami ohledně podmínek podnikání, procedur, organizační

struktury, norem a regulací, ...

- Dokumentace Enterprise IT architektury (procesy poskytování informací, portfolio aplikací a systémů, relevantní technologie a lidé potřební pro plánování, vývoj, provoz a podporu aplikací);
- Výběr odpovídajícího kontrolního rámce;
- Identifikace odpovídajících IT procesů na základě vybraného kontrolního rámce;
- Výběr IT komponent (aplikace, informace, infrastruktura, lidé);
- Úprava výběru IT komponent s ohledem na jejich přímý vztah k relevantním procesům;
- Prvotní výběr kontrolních cílů relevantních pro IT procesy ve scope;
- Iterativní úprava výběru relevantních kontrolních cílů.

Obecně lze stanovit rozsah na třech úrovních detailu: (1) na nejvyšší úrovni detailu, kdy postupuji od definice byznys a IT cílů pro dané univerzum, identifikaci relevantních IT procesů a jimi používaných zdrojů, (2) na hrubé úrovni detailu mohu vycházet z obecné hierarchie cílů a procesů vycházející z výzkumu ITGI a (3) hybridní přístup představující kombinaci obou uvedených.

Při pokusu namapovat kroky konvenčních přístupů k auditu datové kvality bychom nejspíš dospěli k závěru, že v rámci této fáze jsou dále detailněji rozpracovávány a konkretizovány kroky již uvedené. U Larry Englishe snad navíc přibude krok S2.2 (Definice charakteristik, které budou měřeny) odpovídající definici klíčových kontrolních cílů.

Realizace

Vlastní realizace iniciativy ujištění se skládá z následujících kroků:

- Upřesnění porozumění předmětu ujištění;
- Upřesnění rozsahu klíčových kontrolních cílů pro předmět ujištění;
- Test efektivnosti návrhu kontrol pro klíčové kontrolní cíle;
- Test výstupů klíčových kontrolních cílů;
- Dokumentace dopadu identifikovaných slabin kontrol;
- Formulace celkového závěru a doporučení, jejich komunikace.

V rámci kroku 1 zřejmě u Englishe a McGilvray opět probíhá redefinice kroků namapovaných ve fázi Plánování. K upřesnění rozsahu kontrolních cílů lze přiřadit Englishův krok S2.5 (Identifikace zdrojů, proti nimž je měřena správnost dat). Přiřazení kroků k „Testování efektivnosti návrhu kontrol“ a „Testování výstupů kontrolních cílů“ je diskutabilní a je snazší u kroků L. Englishe. Zatímco krok S1.4 (Technický assessment kvality definice pro zajištění shody s datovými standardy a směrnicemi) skutečně svou náplní alespoň částečně odpovídá „Testování efektivnosti návrhu kontrol“ a kroky S1.5 (Assessment kvality informační architektury), S2.6 (Náhodný výběr dat pro assessment), S1.6 (Hodnocení spokojenosti s definicí dat), S2.7 (Měření na vzorku dat) odpovídá „Testování výstupu kontrolních cílů“, u McGilvray je pokrytí této části procesu ujištění nejisté. Kroky S3.1 – S3.9 odpovídající měření vlastností dat lze v kontextu IT Assurance Guide chápat spíše jako činnosti nutné při identifikace byznys dopadů slabin jednotlivých kontrol. Při použití IT Assurance Guide pro audit datové kvality by tudíž bylo nutné náplň tohoto kroku upravit tak, aby umožňoval konvenční zjišťování vlastností dat i v případech, kdy např. pro skupinu atributů není sledován daný kontrolní cíl nebo byly zjištěny nedostatky návrhu kontrol.

Ke kroku „Zdokumentování vlivu slabin kontrol“, je možné namapovat většinu zbývajících kroků McGilvray (11 kroků) a L. Englishe (7 kroků). Vesměs se jedná o činnosti související s mapováním vlivu do byznys procesů a kalkulací souvisejících nákladů. U Larryho Englishe sem lze přiřadit navíc „Identifikaci zdrojů dat vyžadujících reengineering (S4.1). Posledním krokem doporučovaným IT Assurance Guide je formulace a zveřejnění celkového závěru a doporučení. Tomuto kroku v podstatě přesně odpovídá v přístupu L. Englishe S2.8 (Interpretace zjištění a prezentace / reporting informační kvality).

Komentáře ke článku

©2011 - 2021 D. Pejčoch